

Análise Forense Digital e a Inteligência de Ameaças Cibernéticas

MÓDULO 6 | Inteligência de ameaças cibernéticas - Fundamentos

NOME: Gonçalo João Santos Silva
N.º DE ESTUDANTE: 2000499
DATA DE ENTREGA: 26/10/2025

Atividade A — Mapear um ataque à MITRE ATT&CK

Com base no exemplo de ciberataque à UBER, li atentamente o artigo Unpacking the Uber Breach para identificar a narrativa em fases (Initial Access → Discovery → Privilege Escalation → Access Secrets → Exfiltration).

Identifiquei e selecionei as ações técnicas do atacante descritas no artigo (ex: “attacker got inside... VPN credentials”, “PowerShell script containing hard-coded privileged credentials”, “downloaded some internal Slack messages...”).

Registei as citações relevantes do artigo, assegurando fidelidade ao texto original que descrevem cada fase. Estas frases formam a coluna (Evidência) da tabela. Exemplos:

“Phase 1: Initial Access. The attacker got inside Uber’s IT environment by gaining access to credentials to Uber’s VPN infrastructure.”

“PowerShell script containing hard-coded privileged credentials to Uber’s PAM solution.”

“the attacker ‘downloaded some internal Slack messages, as well as accessed or downloaded information from an internal tool our finance team uses to manage some invoices.’”

Agrupamento por fase/tática ATT&CK

O agrupamento das ações por fases segue a metodologia do Ciclo de Inteligência e utiliza o framework MITRE ATT&CK como referência para mapear táticas e técnicas. Esta abordagem permite correlacionar os artefactos forenses com comportamentos adversários conhecidos, orientar as buscas por evidência relevante e apoiar a priorização das ações de investigação.

Artefactos forenses e comandos

Para cada técnica mapeada indiquei os artefactos que devem ser recolhidos ou verificados (por exemplo: logs de autenticação, ficheiros suspeitos, entradas Sysmon/EventID, cópias em disco) e forneci exemplos práticos de comandos e caminhos para os localizar. Estes exemplos são destinados a guiar a recolha e a triagem inicial de evidência em ambiente Windows/Linux e em infraestrutura de rede.

Nível de confiança

Atribuí a cada mapeamento um nível de confiança (Alta / Média / Baixa). “Alta” significa que a técnica está explicitamente descrita na fonte primária; “Média” indica que a técnica é uma inferência plausível suportada por indícios; “Baixa” sinaliza hipóteses com pouca evidência direta. Esta categorização facilita a distinção entre factos confirmados e inferências durante a análise forense e na produção de relatórios.

Tabela

Fase Nº	Tática ATT&CK	Técnica (nome + ID)	Sub-técnica (ID)	Evidência (fonte — CyberArk)	Justificação curta	Artefactos / Logs a procurar (exemplos / comandos)	Ferramentas / Malware referidos	Confiança
1	Initial Accesses	Valid Accounts T1078	—	“Phase 1: Initial Access. The attacker got inside Uber’s IT environment by gaining access to credentials to Uber’s VPN infrastructure.” (CyberArk)	A fonte descreve acesso inicial usando credenciais válidas para a VPN. Correspondendo a T1078.	VPN auth logs (VPN server logs), AD authentication logs (EventID 4624), SIEM alerts. Exemplos: wevtutil qe Security /q:"*[System[(EventID=4624)]]"; export VPN auth CSV.	—	Alta
2	Discovery / Credential Access	Credentials in Files — T1552.001 (Credentials in Files)	—	“Phase 2: Discovery. ... discovered a PowerShell script containing hard-coded privileged credentials to Uber’s PAM solution.” (CyberArk)	A presença de credenciais hard-coded num script PowerShell é descrição directa de T1552.001.	Procurar ficheiros PowerShell em shares: listar network share (dir \\server\share /s), obter hash do ficheiro (Get-FileHash), analisar conteúdo (strings, grep). Verificar historial do share, auditoria SMB.	PowerShell script identificado	Alta
3	Privilege Escalation / Credential Access	Credentials from Password Stores — T1555	—	“Phase 3: Privilege Escalation, Access PAM System. By harvesting the hard-coded admin credentials for the privileged access management solution, the attacker was able to further escalate privileges.” (CyberArk)	Descreve explicitamente e acesso a credenciais do PAM e uso para escalonamento. mapeia para T1555.	Logs do PAM (audit trail), access logs de consoles cloud, API logs, EDR telemetry de process actions. Exemplos: export de audit trail do PAM; verificar ações de vault access com timestamps.	PAM (Privileged Access Management) citado	Alta
4	Lateral Movement / Credential Access	Use of Valid Accounts / Remote Services	—	“Phase 4: Access Secrets from PAM System, Reach Critical	Uso de segredos do PAM para aceder a sistemas críticos sugere	Logs de acesso a consoles, conexões RDP/SSH (EventIDs 4624/4648, Sysmon NetworkConnect), cloud console audit. Exemplos: Get-WinEvent - FilterHashtable @{LogName='Security'; ID=4624}; Sysmon Event ID 3.	—	Média

		— T1021 / T1078		Company Systems. ... attacker ultimately gained 'elevated permissions to a number of tools.'" (CyberArk)	movimento lateral por contas válidas ou uso de serviços remotos. T1021 / T1078.			
5	Collection / Exfiltration	Exfiltration Over Web Services — T1567 (ou Exfil via C2 T1041)	—	"Phase 5: Data Exfiltration ... the company confirmed that the attacker 'downloaded some internal Slack messages, as well as accessed or downloaded information from an internal tool our finance team uses to manage some invoices.'" (CyberArk)	A fonte descreve descarregamento de mensagens e dados, corresponde a exfiltração para web services (T1567) ou transferência de dados via C2 (T1041) dependendo do canal.	Proxy logs, firewall logs, TLS/HTTP logs, web server logs, packet capture (if available). Exemplos: analisar logs proxy para endpoints e tamanhos de payload; tshark -r capture.pcap -Y "http.request.method == 'POST'".	—	Alta
6	Persistence / Defense Evasion	Possible Scheduled Task / Registry Run Keys — T1053 / T1547.001	—	Fonte não detalha explicitamente mecanismo de persistência; indica "elevated permissions" e uso continuado de ferramentas. (inferência baseada no padrão de ataque e práticas comuns).	A fonte não descreve um mecanismo exacto de persistência; inclusão como hipótese para investigação forense.	Windows Scheduled Tasks (schtasks /query), Registry Run keys (HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run), autoruns. Verificar eventos Task Scheduler (EventID 4698).	—	Média (inferência)

Explicação

Fase 1 - Initial Access → T1078 (Valid Accounts)

Texto da fonte:

“Phase 1: Initial Access. The attacker got inside Uber’s IT environment by gaining access to credentials to Uber’s VPN infrastructure.”

Raciocínio:

A técnica T1078 descreve o uso de credenciais válidas para aceder. A frase é explícita: “gaining access to credentials to Uber’s VPN”. Logo, mapeamento directo.

- Evidência forense a recolher: VPN server auth logs (user, timestamp, source IP), AD logs (EventID 4624), correlacionar IPs e horários com sessões anómalas.
- Comando / caminho exemplo: exportar logs do appliance VPN; wevtutil qe Security /q:"*[System[(EventID=4624)]]" para Windows.

Fase 2 - Discovery / Credential Access → T1552.001 (Credentials in Files)

Texto da fonte:

- “discovered a PowerShell script containing hard-coded privileged credentials to Uber’s PAM solution.”

Raciocínio:

T1552.001 cobre credenciais armazenadas em ficheiros; a fonte cita exactamente “hard-coded privileged credentials in PowerShell script”. mapeamento directo.

- Evidência forense: conteúdo do ficheiro PowerShell (hash, strings), lista de modificações no share, backups/Shadow Copies, EDR file telemetry.
- Comando exemplo: Get-FileHash C:\path\to\script.ps1 -Algorithm SHA256 e strings script.ps1 | Select-String -Pattern "password|secret".

Fase 3 - Privilege Escalation → T1555 (Credentials from Password Stores)

Texto da fonte:

“By harvesting the hard-coded admin credentials for the privileged access management solution, the attacker was able to further escalate privileges.”

Raciocínio:

- Uso de credenciais do PAM para aceder a segredos e obter privilégios corresponde a T1555. A fonte descreve isto claramente.
- Evidência: logs do PAM (vault access), registos de API e auditoria, listas de comandos executados após acesso aos segredos.
- Comando / acção: export audit trail do PAM; procurar entradas de sessão que coincidem com timestamps do acesso inicial.

Fase 4 - Lateral Movement / Use of Elevated Accounts → T1021 / T1078

Texto da fonte:

“attacker ultimately gained ‘elevated permissions to a number of tools’” (acesso a sistemas críticos).

Raciocínio:

Depois de obter segredos do PAM, o atacante usou essas credenciais para aceder a outras ferramentas/sistemas, padrão típico de movimento lateral com contas válidas ou serviços remotos; por isso T1078/T1021 são aplicáveis. A fonte descreve o resultado, não o mecanismo exato por isso confiança média.

- Evidência: logs de acesso a consoles, conexões RDP/SSH, Sysmon NetworkConnect event ID 3, correlacionar processos iniciados com sessão.
- Comando exemplo: Get-WinEvent -FilterHashtable @{LogName='Security'; ID=4624} e analisar Sysmon event 1/3.

Fase 5 - Exfiltration → T1567 (Exfiltration Over Web Services)

Texto da fonte:

“downloaded some internal Slack messages, as well as accessed or downloaded information from an internal tool our finance team uses to manage some invoices.”

Raciocínio:

Descarregar mensagens e dados corresponde a exfiltração; dado que Slack/serviço web foi usado, T1567 (Exfiltration Over Web Services) é apropriado. Se a transferência foi via C2, T1041 seria alternativa; porém a fonte aponta para web service downloads. Confiança alta.

- Evidência: proxy logs (requests to slack.com or other endpoints), logs da aplicação interna, logs S3/HTTP, captura de tráfego se disponível.
- Comando exemplo: `tshark -r capture.pcap -Y "http && ip.addr == x.x.x.x"` ou analisar proxy logs por user agent / destinations.

Fase 6 - Persistência / Defense Evasion (inferência)

A CyberArk não especifica mecanismo de persistência (startup, scheduled task, services) apenas registra o uso continuado de ferramentas.

Atividade B - Perfil de ameaça com base num relatório CTI - CISA Advisory AA25-203A

1 . Qual é o principal ator de ameaça identificado neste relatório, as suas vítimas tipo e a sua motivação?

O ator de ameaça é o grupo Interlock, associado a uma campanha de ransomware com dupla extorsão (exfiltra dados e posteriormente cifra os sistemas).

Motivação: lucro financeiro.

Vítimas: empresas e entidades dos setores:

- Infraestruturas críticas
- Saúde
- Serviços empresariais
- Tecnologia
- Governo

Regiões principais: América do Norte e Europa

Como cheguei à conclusão: secção Summary e Impact do advisory.

2 . Que vetor de acesso inicial foi explorado?

O acesso inicial foi realizado através de:

- **Drive-by compromise** em websites legítimos comprometidos → T1189
- **Engenharia social com execução via PowerShell** após CAPTCHA falso → T1204.004

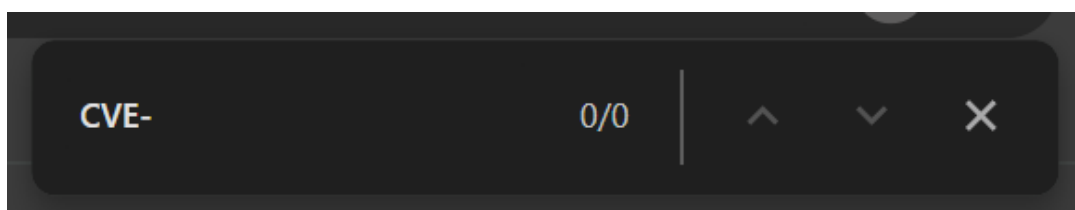
Recolhido da secção Initial Access do advisory.

Drive-By Compromise	T1189	Interlock actors obtain initial access by compromising a legitimate website that network users visit, or by disguising malicious payloads as fake browser updates or common security software, including the following:¹⁷ ▪ FortiClient.exe ▪ Ivanti-Secure-Access-Client.exe ▪ GlobalProtect.exe ▪ Webex.exe ▪ AnyConnectVPN.exe ▪ Cisco-Secure-Client.exe ▪ zyzoom_antimalware.exe Interlock actors also gain access via the ClickFix social engineering technique, in which users are tricked into executing a malicious payload by clicking on a fake CAPTCHA that prompts users to execute a malicious PowerShell script.
---------------------	-----------------------	---

3 . Que vulnerabilidade específica (CVE) foi utilizada, se indicada?

Nenhuma CVE é explicitamente indicada no advisory.

A abordagem foca-se em técnicas, não exploits de vulnerabilidades.



4 . Qual foi a principal técnica MITRE ATT&CK associada ao acesso inicial?

A principal técnica para o acesso inicial foi T1189 (Drive-by Compromise). Em complemento, foi usada T1204.004 (User Execution: Malicious Copy & Paste) devido à execução de PowerShell por engenharia social. Para chegar a esta resposta identifiquei as frases do advisory que correspondem ao acesso inicial, depois verifiquei no catálogo MITRE para confirmar os IDs.

Drive-By Compromise	T1189	Interlock actors obtain initial access by compromising a legitimate website that network users visit, or by disguising malicious payloads as fake browser updates or common security software, including the following:¹⁷ ▪ FortiClient.exe ▪ Ivanti-Secure-Access-Client.exe ▪ GlobalProtect.exe ▪ Webex.exe ▪ AnyConnectVPN.exe ▪ Cisco-Secure-Client.exe ▪ zyzoom_antimalware.exe Interlock actors also gain access via the ClickFix social engineering technique, in which users are tricked into executing a malicious payload by clicking on a fake CAPTCHA that prompts users to execute a malicious PowerShell script.
---------------------	-----------------------	---

Technique Title	ID	Use
User Execution: Malicious Copy and Paste	T1204.004	Via the ClickFix social engineering technique, users are tricked into clicking a fake CAPTCHA and prompted into executing a malicious Base64-encoded PowerShell process by following instructions to open a Windows Run window (Windows Button + R), pasting clipboard contents ("CTRL + V"), and then executing the malicious script ("Enter").

5. Que ferramentas ou malware foram utilizados durante o ataque?

As ferramentas/malware identificadas no advisory e confirmadas nos IoCs:

- Cobalt Strike beacon
- SystemBC
- Interlock RAT
- NodeSnake RAT
- Lumma Stealer
- Berserk Stealer
- Keylogger klg.dll
- Ferramentas de exfiltração: AzCopy, WinSCP

Extraídas da secção Tools & Malware + IoCs STIX

type,value,source,date,confidence,note
hash,klg.dll,CISA-AA25-203A,2025-07-22,Alta,"Keylogger utilizado para capturar teclas"
hash,conhost.exe,CISA-AA25-203A,2025-07-22,MÃ©dia,"Mascarado para parecer sistema"
filename,Chrome Updater,CISA-AA25-203A,2025-07-22,MÃ©dia,"PersistÃªncia via RunKey/Startup"
tool,Cobalt Strike,CISA-AA25-203A,2025-07-22,Alta,"Plataforma C2 e movimento lateral"
tool,SystemBC,CISA-AA25-203A,2025-07-22,Alta,"Proxy de C2 para comunicaÃ§Ã£o encoberta"
tool,AzCopy,CISA-AA25-203A,2025-07-22,Alta,"ExfiltraÃ§Ã£o para Azure Blob"
tool,WinSCP,CISA-AA25-203A,2025-07-22,Alta,"ExfiltraÃ§Ã£o via SFTP/FTP"
domain,example-malicious.com,CISA-AA25-203A,2025-07-22,MÃ©dia,"DomÃ-nio fictÃ-cio de exfiltraÃ§Ã£o (exemplo acadÃmico)"
hash,Berserk Stealer,CISA-AA25-203A,2025-07-22,Alta,"Roubo de credenciais"
hash,Lumma Stealer,CISA-AA25-203A,2025-07-22,Alta,"Roubo de credenciais"

iocs_from_xml.csv

6. Que t cnicas de persist ncia ou eleva  o de privil gios foram observadas?

As t cnicas observadas foram:

- Persist ncia: T1547.001 (Run Keys / Startup Folder) - Evid ncia Registo do "Chrome Updater"
- Mascaramento: T1036.005 (Masquerading) - Evid ncia - ficheiros mascarados como conhost.exe
- Eleva  o de privil gios: T1078.002 – Evid ncia - uso de contas de dom nio comprometidas.

7. Que tipos de dados foram exfiltrados, segundo o relatório?

O relatório descreve exfiltração para cloud storage: AzCopy → Azure Blob (T1567.002) e WinSCP (T1048).

Collection and Exfiltration

Interlock actors leverage Azure Storage Explorer (`StorageExplorer.exe`) to navigate victims' Microsoft Azure Storage accounts [T1530] prior to exfiltrating data. According to open source reporting, Interlock actors execute AzCopy to exfiltrate data by uploading it to the Azure storage blob [T1567.002].¹³ Interlock actors also exfiltrate data over file transfer tools, including WinSCP [T1048].

Technique Title	ID	Use
Exfiltration Over Web Service: Exfiltration to Cloud Storage	T1567.002	Interlock actors exfiltrate data to cloud storage by executing AzCopy to upload data to the Azure storage blob.
Exfiltration Over Alternative Protocol	T1048	Interlock actors use file transfer tools like WinSCP to exfiltrate data.

8. Que indicadores de compromisso (IoCs) são fornecidos pela CISA?

O advisory inclui indicadores de compromisso estruturados em formatos STIX/XML e STIX/JSON.

Os IoCs disponibilizados abrangem:

- **Hashes de ficheiros** maliciosos (MD5, SHA1, SHA256)
- **Domínios e infraestrutura** utilizados pelos atacantes
- **Artefactos de malware**, como executáveis e DLLs associados a Cobalt Strike, SystemBC, Interlock RAT e outros

FBI, CISA, HHS, and MS-ISAC encourage organizations to implement the recommendations in the **Mitigations** section of this advisory to reduce the likelihood and impact of Interlock ransomware incidents.

For a downloadable copy of **IOCs**, see:

- [AA25-203A STIX XML](#) (63KB)
- [AA25-203A STIX JSON](#) (57KB)

Estes ficheiros STIX contêm os hashes, domínios e artefactos de malware associados à campanha Interlock, que podem ser importados para plataformas de deteção.

9 . Que medidas de mitigação a CISA recomenda neste advisory?

As principais medidas são: filtragem de DNS (DNS Filtering), utilização de WAF (Web Application Firewall), implementação de MFA/ICAM para todas as contas críticas, patching regular (com foco nas KEVs), segmentação de rede, uso de EDR com monitorização activa, e backups offline.

10 Que táticas e técnicas MITRE ATT&CK foram mais críticas para o sucesso do ataque?

As táticas mais críticas incluem: Initial Access (T1189, T1204.004), Execution (T1059.001), Persistence (T1547.001), Masquerading (T1036.005), Credential Access / Lateral Movement (T1555.x, T1021.001), Collection & Exfiltration (T1530, T1567.002, T1048) e Impact (T1486 - Data Encrypted for Impact). A combinação destas permitiu a cadeia completa de ataque desde o acesso inicial até à exfiltração e cifragem.